ТУСУР
TUSUR UNIVERSITY

ГОСТ Р ИСО/МЭК 27002-2021

Управление информационной безопасностью. Лекция 2.

ГОСТ Р ИСО/МЭК 27002-2021

В стандарте содержатся рекомендации по созданию и практическому использованию в организации СМИБ, включая вопросы выбора, внедрения и применения полноценного набора мер обеспечения ИБ, соответствующих совокупности имеющихся в организации рисков ИБ.

Стандарт предназначен для использования организациями, которые намерены:

- выбрать меры обеспечения ИБ в процессе внедрения системы менеджмента информационной безопасности на основе ИСО/МЭК 27001;
- внедрить общепринятые меры обеспечения ИБ;
- разработать свои собственные руководства по менеджменту ИБ.

Стандарт состоит из 14 разделов, содержащих в совокупности 114 конкретных мер обеспечения ИБ, сгруппированных в 35 основных категорий.

Требования информационной безопасности

Крайне важно, чтобы организация определила применимые требования безопасности. Существует три основных источника требований безопасности:

- оценка рисков для организации с учетом общей бизнес-стратегии и целей организации. Посредством оценки риска выявляют угрозы активам, оценивают уязвимости, вероятности возникновения и предполагаемое потенциальное воздействие;
- юридические, законодательные, нормативные и договорные требования, которые должна выполнять организация, ее торговые партнеры, подрядчики и поставщики услуг, а также их социально-культурная среда;
- набор принципов, целей и требований бизнеса по обращению, обработке, хранению, передаче и архивированию информации, которые организация разработала для поддержки своей деятельности.

Ресурсы, используемые для внедрения мер обеспечения ИБ, должны быть соизмеримы с ущербом для бизнеса, к которому могут привести проблемы безопасности при отсутствии этих мер. Результаты оценки рисков могут стать основанием для принятия соответствующих решений руководством и помогут расставить приоритеты для управления рисками ИБ и внедрения мер обеспечения ИБ, выбранных для защиты от этих рисков.

Выбор мер обеспечения информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Меры обеспечения ИБ могут быть выбраны как из ГОСТ Р ИСО/МЭК 27002-2021, так и из других источников. При необходимости могут быть разработаны новые меры для удовлетворения специфичных потребностей организации.

Выбор мер обеспечения ИБ зависит от организационных решений, основанных на критериях принятия риска, вариантах обработки риска и общем подходе к управлению рисками, применяемому в организации, а также должен учитывать соответствующее национальное и международное законодательство и нормативное регулирование. При выборе мер для обеспечения надежной информационной безопасности необходимо предполагать, как меры могут взаимодействовать между собой.

Некоторые из мер обеспечения ИБ, приведенных в стандарте, могут рассматриваться как руководство по менеджменту ИБ и применимы для большинства организаций.

Разделы ГОСТ Р ИСО/МЭК 27002-2021

1. Политики информационной безопасности.
2. Организация деятельности по информационной безопасности.
3. Безопасность, связанная с персоналом.
4. Менеджмент активов.
5. Управление доступом.
6. Криптография.
7. Физическая безопасность и защита от воздействия окружающей среды.
8. Безопасность при эксплуатации.
9. Безопасность системы связи.
10. Приобретение, разработка и поддержка систем.
11. Взаимоотношения с поставщиками.
12. Менеджмент инцидентов информационной безопасности.
13. Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации.
14. Соответствие требованиям.

Каждый раздел, посвященный мерам обеспечения ИБ, содержит описание одной или нескольких основных категорий. Порядок следования разделов в стандарте не отражает их важности.

Категории мер обеспечения ИБ

Каждая основная категория содержит:

a) цель применения мер, которая содержит описание того, что должно быть достигнуто;
b) одну или несколько мер обеспечения ИБ, которые могут быть применены для достижения цели применения меры.

Описание меры обеспечения ИБ структурировано следующим образом:

Мера обеспечения ИБ. Определяет конкретную формулировку меры, направленную на достижение цели применения меры.

Руководство по применению. Предоставляет более подробную информацию для помощи в реализации меры и достижения целей управления. Руководство может не совсем подходить или быть недостаточным для всех ситуаций и может не соответствовать специфичным требованиям организации к мере обеспечения ИБ.

Дополнительная информация. Содержит дополнительную информацию, которую следует принять во внимание, например вопросы юридического характера или ссылки на другие стандарты. Если дополнительной информации нет, то эта часть отсутствует.

Рассмотренные вопросы

- Назначение и структура ГОСТ 27002

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021
- Создание СМИБ по новому ГОСТу: разбираемся в ключевых понятиях и новшествах за 5 минут https://habr.com/ru/articles/661407/

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!